

# Clase 163 — Emulación de adversarios

Parte: **7 — Red Team y operaciones ofensivas** · Fuente: *MITRE Adversary Emulation Plans / CTID* 

Duración estimada: **100 min** · Nivel: **Intermedio**

## Objetivo

Aprender a transformar threat intelligence sobre un actor real en un **plan de emulación** ejecutable: qué técnicas usa, en qué orden, con qué herramientas, y cómo reproducir su comportamiento de forma controlada para poner a prueba las defensas. El alumno pasará de "hacer hacking genérico" a "actuar como APT29 lo haría".

## Resultados de aprendizaje

Al finalizar, el alumno podrá:

1. **Distinguir** emulación, simulación y ataque oportunista.
2. **Extraer** TTPs de un informe de CTI y estructurarlos en fases.
3. **Construir** un plan de emulación con la MITRE Emulation Library como base.
4. **Seleccionar** herramientas que reproduzcan cada TTP fielmente.
5. **Definir** los criterios de "detectado/no detectado" por cada fase.

## Temas

| # | Tema                            | Por qué importa                                    |
|---|---------------------------------|----------------------------------------------------|
| 1 | Emulación vs simulación         | Precisión del realismo que se busca                |
| 2 | Threat intelligence como insumo | El plan nace de datos, no de intuición             |
| 3 | Emulation Library de MITRE      | Planes listos y validados por la comunidad         |
| 4 | Fases y encadenamiento de TTPs  | El orden importa para el realismo                  |
| 5 | Selección de herramientas       | Reproducir el comportamiento, no el binario exacto |
| 6 | Micro-emulaciones (CTID)        | Emulaciones atómicas y reutilizables               |
| 7 | Criterios de detección por fase | Convierten la emulación en medición                |

## Definiciones y características

- **Adversary emulation:** reproducción fiel del comportamiento de un actor específico basada en CTI. Característica: imita TTPs, no solo objetivos.
- **Adversary simulation:** uso de comportamientos adversariales genéricos sin atarse a un actor. Característica: menos específica, más rápida.
- **TTP (Tactics, Techniques, Procedures):** la firma comportamental de un actor. Característica: más difícil de cambiar que un IOC.

- **Emulation Plan:** documento paso a paso que reproduce a un actor. Característica: encadena TTPs con herramientas y comandos.
- **CTI (Cyber Threat Intelligence):** información sobre actores, campañas y TTPs. Característica: es la materia prima del plan.
- **Micro-emulation:** emulación de un comportamiento pequeño y aislado (CTID). Característica: modular y componible.

## Herramientas y preparación

- [MITRE Adversary Emulation Library](#).
- Informes de CTI públicos (Mandiant, CrowdStrike, Microsoft, DFIR Report).
- El laboratorio de las clases siguientes (C2 + AD lab) para ejecutar el plan más adelante.
- Herramientas de reproducción: Sliver/Mythic (C2), Impacket, y Atomic Red Team (Clase 180) para TTPs atómicos.

⚠ La emulación se ejecuta **solo** en el laboratorio propio. En esta clase construimos el plan en papel; su ejecución práctica llega con la infraestructura de las clases 164 en adelante y el AD lab.

## Laboratorio guiado

1. **Elige un actor.** Toma APT29 (usaremos el plan público de la Emulation Library como referencia).
2. **Lee la CTI base.** Revisa 2 informes públicos y anota las técnicas mencionadas con su ID ATT&CK.
3. **Descarga el plan de MITRE.** Clona la Emulation Library y abre el plan de APT29; identifica sus fases (Initial Access → Discovery → Credential Access → Lateral Movement → Collection → Exfiltration).
4. **Estructura tu plan.** Crea una tabla con columnas: Fase | Técnica (ID) | Herramienta | Comando/acción | Detección esperada.
5. **Selecciona herramientas por TTP.** Para "PowerShell download cradle" ( T1059.001 ), decide reproducirlo con un stager de tu C2; para "credential dumping" ( T1003.001 ), con un método equivalente a Mimikatz en el lab.
6. **Encadena las fases.** Ordena los TTPs de forma que cada uno habilite al siguiente (ej. discovery antes que lateral movement).
7. **Define criterios de éxito y detección.** Por cada fila, escribe qué evento debería generar y quién debería verlo.

## Ejercicios

1. Explica con un ejemplo la diferencia entre emulación y simulación.
2. Extrae 8 TTPs de un informe público de CTI y mapéalos a ATT&CK.
3. Ordena esos 8 TTPs en fases coherentes de un ataque.
4. Elige una herramienta para reproducir cada uno de 5 TTPs.
5. Redacta el criterio de detección para tres fases.
6. Compara dos planes de la Emulation Library y señala una diferencia de estilo entre los dos actores.

## Reto verificable

Entrega un **plan de emulación de una página** para un actor de tu elección (con base en CTI pública), que contenga al menos 10 TTPs organizados en 5 fases, la herramienta de reproducción por TTP y la detección esperada. **Criterio de aceptación:** cada TTP tiene ID ATT&CK válido, hay continuidad lógica entre fases (cada una habilita la siguiente) y las herramientas elegidas reproducen el comportamiento descrito en la CTI.

## Errores comunes

| Síntoma / mensaje                        | Causa y cómo arreglar                                                  |
|------------------------------------------|------------------------------------------------------------------------|
| El plan es una lista sin orden           | Faltan fases; encadena TTPs por dependencia                            |
| Se copia el malware del actor            | No es necesario ni seguro; reproduce el comportamiento, no el binario  |
| TTPs sin fuente                          | Emulación inventada; ancla cada técnica a un informe de CTI            |
| No se puede medir                        | Faltan criterios de detección; añádelos por fase                       |
| Se elige un actor irreal para el entorno | Emular ICS en una red ofimática no aporta; ajusta el actor al objetivo |

## Preguntas frecuentes

 **¿Necesito el malware real del actor?** No. Emulas el **comportamiento** (TTPs) con herramientas seguras y controladas. Usar malware real es peligroso e innecesario.

 **¿De dónde saco los TTPs de un actor?** De su página en ATT&CK (Groups), informes de proveedores de CTI y de la Emulation Library de MITRE.

 **¿Emulación o simulación para un cliente nuevo?** La simulación (comportamientos genéricos) suele ser mejor punto de partida; la emulación de un actor específico aporta más cuando el cliente tiene un modelo de amenaza claro.

## Referencias

- MITRE CTID — *Adversary Emulation Library*. [https://github.com/center-for-threat-informed-defense/adversary\\_emulation\\_library](https://github.com/center-for-threat-informed-defense/adversary_emulation_library)
- MITRE — *Adversary Emulation Plans*. <https://attack.mitre.org/resources/adversary-emulation-plans/>
- Vest & Tubberville — *Red Team Development and Operations*.
- Mandiant / CrowdStrike — informes públicos de threat intelligence.

## Siguiente clase

Clase 164 - Diseño de infraestructura de comando y control (C2)